



CYBERSECURITY TABLETOP EXERCISE

SSRF to AWS Credential Compromise

Server-Side Request Forgery exploitation leading to EC2 metadata service access and IAM credential theft with subsequent customer data exfiltration

SCENARIO TYPE

Technical - Cloud Security

TARGET AUDIENCE

**SOC Analysts, Incident
Response, DevOps/Cloud
Security, Application
Security**

DURATION

90-120 minutes

DIFFICULTY

Intermediate

Executive Summary

This tabletop exercise simulates a critical security incident where a threat actor exploits a Server-Side Request Forgery (SSRF) vulnerability in your web application's image processing API to access the AWS EC2 instance metadata service (169.254.169.254). The attacker successfully steals temporary IAM role credentials and uses them to exfiltrate 8.4 GB of customer data (500,000+ records) from S3 buckets before attempting destructive actions. The scenario tests your organization's ability to detect SSRF vulnerabilities, respond to AWS credential compromise, manage data breach notifications, and implement proper cloud security controls.

Key Points

Attack Vector

SSRF vulnerability in image resize API endpoint allows unrestricted outbound HTTP requests to AWS metadata service

Potential Impact

Customer data breach (500K+ records), GDPR/CCPA notification requirements, potential \$200K+ in lost revenue from service disruption, reputation damage

Testing Goals

Validate SSRF response procedures, test AWS credential rotation speed, assess CloudTrail/GuardDuty monitoring effectiveness, identify gaps in application security

Critical Gaps

SSRF incident response playbook, AWS credential compromise procedures, data breach notification protocols, IMDSv2 enforcement

02 Scenario Overview

Your organization operates an e-commerce platform hosted on AWS. The web application includes an image resize API endpoint that accepts user-supplied URLs. A threat actor discovers this endpoint lacks proper input validation and crafts malicious requests targeting 169.254.169.254 (AWS metadata service). By exploiting the SSRF vulnerability, the attacker retrieves IAM role credentials attached to the EC2 instance. These temporary credentials provide read access to S3 buckets containing customer data. The attacker uses CloudTrail-visible API calls from an external IP address to enumerate and download 8.4 GB of customer records before attempting destructive actions (object deletion) and issuing a potential ransomware demand.

Attack Chain Timeline

T+0

SSRF Vulnerability Discovery

AWS WAF generates alert for suspicious request pattern. Request contains AWS metadata service IP (169.254.169.254) in image_url parameter. WAF rule is in detection-only mode and allows request through.

Impact: Security team has opportunity for early detection if logs are monitored

T+15

IAM Credential Theft Confirmed

Application debug logs reveal successful metadata service access. Server fetched IAM role credentials and returned them to attacker in API response. Role provides S3 read access to customer data bucket.

Impact: Attacker now has valid AWS credentials with 6-hour expiration. Can access customer data in S3

T+30

Data Exfiltration Begins

CloudTrail shows S3 API calls (ListBucket, GetObject) from external IP 203.0.113.42. Total of 2,347 files accessed from company-customer-data bucket. 8.4 GB data transferred over 30 minutes.

Impact: Data breach in progress. 500K+ customer records including PII (names, emails, addresses, encrypted payment tokens) exfiltrated

T+45

Containment Decision Point

Security team must decide between immediate application shutdown vs. WAF blocking vs. patch-first approach. Each option has trade-offs for business continuity and security.

Impact: Decision determines scope of further compromise and revenue impact (\$50K/hour if site is down)

T+60

Media Inquiry - External Pressure

Journalist from TechCrunch contacts company about reported breach. Claims anonymous tip about customer data theft from AWS. Requests statement for article publishing in 1 hour.

Impact: Tests external communication procedures. Unauthorized statements could worsen PR damage

T+75

Destructive Actions - Object Deletion

GuardDuty alert: Unusual S3 DeleteObject activity. Attacker deleted 12,450 product images from company-product-images bucket. Email received with ransom demand (50 BTC) threatening to delete customer data next.

Impact: Service disruption (missing product images). Potential data loss if S3 versioning not enabled. Ransomware escalation threat

T+90

Root Cause Identified

Forensic investigation identifies SSRF vulnerability in image resize endpoint. No URL validation, IMDSv1 accessible, application returns full response body to user. Vulnerability existed for 6+ months.

Impact: Root cause understanding enables proper remediation. Reveals need for SAST tools and secure coding practices

03 Exercise Objectives

1

Test SSRF Detection and Response Procedures

Evaluate the team's ability to identify SSRF vulnerabilities from WAF alerts and application logs, then execute appropriate containment procedures.

Success Criteria:

- SSRF vulnerability recognized within 30 minutes of initial alert
- Containment decision made with clear rationale and stakeholder alignment
- Application security team engaged for emergency patching within 1 hour
- WAF configuration reviewed and updated to block mode for critical rules

2

Validate AWS Credential Rotation Procedures

Test procedures for rapidly revoking compromised IAM credentials and preventing further unauthorized access to AWS resources.

Success Criteria:

- IAM role credentials revoked within 15 minutes via deny policy attachment
- Blast radius assessment completed identifying all accessible resources
- CloudTrail forensic analysis performed to identify attacker actions
- All affected S3 objects and resources documented

3

Assess Cloud Security Monitoring Capabilities

Evaluate effectiveness of CloudTrail logging, GuardDuty alerts, and S3 access monitoring in detecting and responding to credential abuse.

Success Criteria:

- Data exfiltration detected from CloudTrail logs within 20 minutes
- GuardDuty findings reviewed and acted upon appropriately
- S3 access patterns analyzed to determine scope of data accessed
- Network-based indicators (external IPs) correlated with threat intelligence

4

Identify Gaps in Cloud IAM Practices

Discover missing procedures, policies, and technical controls related to AWS security and application security.

Success Criteria:

- Minimum 5 critical/high-priority SOPs identified as missing or inadequate
- IMDSv2 enforcement gap identified as root cause enabler
- Application security testing (SAST/DAST) gaps documented
- Action items assigned with owners and deadlines for remediation

04 Facilitator Guide

Facilitator Role: Guide discussion without providing answers. Use open-ended questions to draw out participant thinking. Maintain psychological safety and encourage honest dialogue.

T+0

AWS WAF Alert - Suspicious URL Parameter Pattern

SSRF-DISCOVER-001

Scenario Development

AWS WAF detects multiple requests with AWS metadata service IP address (169.254.169.254) in the image_url parameter of your image resize API. The WAF rule 'Suspicious URL Parameter Pattern' is currently in detection-only mode and allowed the requests through with a 200 OK response.

Artifact to Deliver

```
POST /api/v1/images/resize HTTP/1.1
Host: api.company.com
Content-Type: application/json
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64)
X-Forwarded-For: 203.0.113.42

{
  "image_url": "http://169.254.169.254/latest/meta-data/iam/security-credentials/",
  "width": 800,
  "height": 600
}

Response: 200 OK
Body: webapp-production-role
```

Expected Response

Security team recognizes SSRF attempt targeting AWS metadata service. Team investigates application logs for successful exploitation and checks CloudTrail for unusual IAM credential usage from external IPs.

Discussion Questions

- What is 169.254.169.254 and why is it significant in AWS environments?
- Should your WAF be in block mode or detection-only mode for this type of rule?
- What logs would you check first to determine if this SSRF attempt was successful?
- How quickly can you patch this vulnerability vs. implementing WAF blocking?

Conditional Responses

If participants ask: "What logs should we check?"

Response: Application logs show 15 similar requests over the past 30 minutes, all returning 200 OK responses with JSON data (not image data). The response bodies contain AWS credential information including AccessKeyId and SecretAccessKey.

If participants ask: "What's the attacker's IP address?"

Response: Source IP is 203.0.113.42. WHOIS shows it belongs to a hosting provider in Eastern Europe. No prior legitimate traffic from this IP address in your logs.

Scenario Development

Application debug logs reveal that the backend server successfully fetched IAM role credentials from the metadata service and returned them to the attacker in the HTTP response. The compromised IAM role has S3 read permissions.

Artifact to Deliver

```
[2026-02-06 10:15:23] INFO: Image resize request received
  image_url: http://169.254.169.254/latest/meta-data/iam/security-
credentials/webapp-production-role

[2026-02-06 10:15:24] DEBUG: HTTP GET http://169.254.169.254/.../webapp-
production-role
Response Status: 200
Response Body: {
  "Code": "Success",
  "Type": "AWS-HMAC",
  "AccessKeyId": "ASIA...[redacted]",
  "SecretAccessKey": "[redacted]",
  "Token": "[redacted]",
  "Expiration": "2026-02-06T16:00:00Z"
}
```

Expected Response

Team confirms IAM credential theft. Security team investigates the compromised role's permissions by reviewing IAM policies. Team initiates credential rotation procedures and checks CloudTrail for evidence of credential abuse.

Discussion Questions

- The attacker now has temporary AWS credentials. What can they do with these?
- How would you determine what permissions this IAM role has?
- What's your immediate containment action - revoke credentials or shut down

Conditional Responses

If participants ask: "What permissions does this role have?"

Response: IAM role policy grants: S3 GetObject/PutObject/ListBucket on company-product-images bucket, S3 GetObject/ListBucket on company-customer-data bucket, EC2 DescribeInstances, DescribeSecurityGroups. The role has READ access to your customer data S3 bucket.

If participants ask: "How do we revoke these credentials?"

Response: Options: 1) Attach explicit deny policy to IAM role (immediate, ~60 seconds to propagate), 2) Modify role trust policy to require specific source IP/VPC, 3) Delete IAM role (breaks production app), 4) Terminate EC2 instances to force credential refresh (causes outage).

Scenario Development

CloudTrail logs reveal the stolen IAM credentials are being used from external IP 203.0.113.42 (not your EC2 IP ranges). Attacker performed S3 ListBucket followed by mass GetObject requests downloading 2,347 files totaling 8.4 GB from customer data bucket.

Expected Response

Team recognizes credentials are being used externally. Identifies 8.4 GB customer data exfiltration in progress. Initiates emergency credential revocation via deny policy. Begins forensic investigation to determine exactly what data was accessed. Discusses data breach notification requirements.

Discussion Questions

- How do you immediately stop the attacker from using these stolen credentials?
- What customer data was in those 2,347 CSV files that were downloaded?
- Do you have data breach notification requirements under GDPR, CCPA, or other regulations?
- How do you detect large data transfers out of S3 in the future?

Conditional Responses

If participants ask: "What data was stolen?"

Response: S3 access logs show files accessed include: customers_profile_data_2024.csv (500K records with names, emails, addresses, phone numbers), payment_methods_encrypted.csv (200K records with encrypted payment tokens), order_history_2024_Q4.csv (1.2M order records). Total: 500K+ unique customers affected.

Response: General Counsel advises: Under GDPR you have 72 hours to notify EU data protection authorities. Under California CCPA you must notify affected residents without unreasonable delay. Encrypted payment tokens may not require notification if encryption keys weren't stolen. But PII (names, emails, addresses) definitely requires customer notification.

Scenario Development

Security team must make immediate decision on containment strategy. Options: A) Shutdown application immediately (stops exploitation but costs \$50K/hour in revenue), B) WAF block + IAM deny policy (keeps app online but attacker could change IP), C) Patch application first then rotate (2-4 hour delay but fixes root cause).

Expected Response

Team debates risk vs. business impact. Makes containment decision with clear rationale. Assigns responsibilities for execution. Discusses customer notification timing. Begins coordination with Legal and PR teams.

Discussion Questions

- What factors influence your containment decision?
- Who has authority to make the call on taking the site offline?
- How do you balance security response with business continuity?
- What happens if you choose WAF blocking but the attacker changes IP addresses?

Conditional Responses

If participants ask: "We choose WAF block + deny policy"

Response: You attach deny policy to IAM role. CloudTrail shows API calls from 203.0.113.42 stop immediately. WAF rule added blocking that IP. 5 minutes later... new WAF alert shows SSRF attempts from different IP: 198.51.100.99. Attacker changed IP address. Do you block this one too or take more drastic action?

If participants ask: "We choose to shut down the application"

Response: Application taken offline. All EC2 instances terminated forcing IAM credential refresh. SSRF exploitation stops immediately. Business team estimates \$200K lost revenue during 4-hour emergency patch and deployment. Customer

support receiving complaints about site being down. How do you communicate this externally?

Scenario Development

Journalist calls company main line: 'Hi, this is Alex Chen from TechCrunch. We received an anonymous tip that your company had a security breach and customer data was stolen from AWS. Someone posted screenshots on Twitter of what appears to be your customer database files. Can you confirm the breach? How many customer records were exposed? Was payment information stolen? I'm publishing a story in the next hour. Do you have a statement?'

Expected Response

Receptionist routes to PR/Communications team per media inquiry procedures. PR coordinates with Legal and Security before providing any statement. No unauthorized comments made. Prepared holding statement provided if appropriate.

Discussion Questions

- Who in your organization has authority to speak to media about security incidents?
- What information can/should you share at this stage of the investigation?
- How do you verify this is a real journalist and not social engineering?
- What happens if an employee makes unauthorized statements to the press?

Conditional Responses

If participants ask: "We provide no comment"

Response: Journalist publishes article anyway with headline: '[Company] Refuses to Comment on Reported Customer Data Breach'. Article includes leaked screenshots. Customers tweeting asking if their data was stolen. Support queue has 500+ tickets. Stock price drops 8%. Board of Directors requesting emergency briefing.

If participants ask: "We provide prepared statement"

Response: PR provides: 'We are aware of a security incident affecting our systems. We are investigating and will provide updates to affected customers as appropriate. Customer security is our top priority.' Journalist asks follow-up: 'Can you confirm customer data was stolen?' How do you respond?

Scenario Development

GuardDuty finding: 'Impact:S3/ObjectDelete.Unusual - An IAM principal invoked an API commonly used to delete data in an S3 bucket.' Attacker deleted 12,450 product images from company-product-images bucket using the compromised credentials. Email received at support@company.com with ransom demand: 50 BTC (\$1.85M) or customer data will be deleted next.

Expected Response

Team recognizes destructive actions (not just exfiltration). Checks S3 versioning status to determine if objects can be restored. Reassesses attacker motivation (ransomware vs. sabotage). Discusses ransom payment policy with Legal and Finance.

Discussion Questions

- Why would the attacker delete product images?
- Do you have S3 versioning enabled to restore these objects?
- Is this a credible ransomware threat or an extortion attempt?
- What's your organization's policy on paying ransoms?
- Should you contact law enforcement at this point?

Conditional Responses

If participants ask: "Do we have S3 versioning enabled?"

Response: Versioning is ENABLED on this bucket. Objects are soft-deleted (delete markers created). You can restore all 12,450 files but it will take 2-3 hours. Until then, product pages show broken image links impacting customer experience.

If participants ask: "Should we pay the ransom?"

Response: General Counsel: 'We have backups and can restore data. The attacker didn't encrypt anything, just deleted files. This appears to be an extortion attempt.'

guarantee they won't publish the data anyway. However, this is ultimately a business decision.'

05 Technical Atomics Runbook

For Exercise Runner Only: This section contains exact technical steps to simulate the attack scenario. Follow the timed sequence precisely for realistic exercise delivery.

Pre-Exercise Environment Setup

Action to Perform

Prepare all exercise materials, verify accessibility, and ensure runner familiarity with AWS console navigation and CloudTrail logs.

Commands / Instructions

```
bash

# Verify materials are accessible
ls /exercises/ssrf-aws-2024/
# Should contain:
# - cloudtrail-logs.json
# - iam-policy.json
# - s3-access-logs.csv
# - guardduty-screenshots/
# - waf-alert-screenshot.png
```

Expected Participant Response

All materials staged and accessible. Runner ready to execute timed injects.

Verification Checklist

- ☐ Staged materials accessible in /exercises/ssrf-aws-2024/
- ☐ CloudTrail log excerpts ready to share
- ☐ IAM policy documents available
- ☐ GuardDuty alert screenshots prepared
- ☐ Runner familiar with scenario flow and inject timing

T+0

SSRF-DISCOVER-001

Display WAF Alert

Action to Perform

Show AWS WAF console alert for suspicious request pattern containing metadata service IP. Read alert details aloud or show screenshot to participants.

Expected Participant Response

Security team investigates WAF alert, checks application logs for SSRF exploitation evidence, begins CloudTrail review.

If No Response After 10 Minutes

If no response after 10 minutes, prompt: 'Your AWS WAF has detected suspicious patterns in your image resize API. Multiple requests contain the IP address 169.254.169.254. What does this indicate and what's your first step?'

Provide Application Log Evidence

Action to Perform

Share application log excerpt showing successful metadata service access and credential retrieval. Display the artifact showing AWS temporary credentials in API response.

Expected Participant Response

Team confirms credential theft, reviews IAM role permissions, initiates credential rotation procedures, checks CloudTrail for abuse.

If No Response After 10 Minutes

If team doesn't recognize severity, prompt: 'These logs show your application server fetched AWS credentials from the metadata service and sent them to the attacker in the HTTP response. The attacker now has valid AWS credentials. What can they access?'

Display CloudTrail Findings

Action to Perform

Show CloudTrail logs or GuardDuty alert indicating API calls from external IP 203.0.113.42. Highlight S3 ListBucket and GetObject calls totaling 8.4 GB data transfer.

Commands / Instructions

```
bash

# If using actual CloudTrail logs:
cat /exercises/ssrf-aws-2024/cloudtrail-logs.json | jq '.Records[] |
select(.sourceIPAddress=="203.0.113.42")'

# Show data exfiltration summary:
echo 'S3 API Calls from 203.0.113.42:'
echo 'ListBucket (company-customer-data): 12 calls'
echo 'GetObject: 2,347 calls'
echo 'Total data transferred: 8.4 GB'
echo 'Duration: 30 minutes'
```

Expected Participant Response

Team recognizes external credential usage, identifies data exfiltration, revokes credentials via deny policy, begins forensic investigation.

If No Response After 10 Minutes

If team is slow to respond, prompt: 'CloudTrail shows 8.4 GB of customer data was just downloaded from your S3 bucket by an external IP using your IAM credentials. How do you stop this immediately?'

Force Containment Decision

Action to Perform

Present three containment options with trade-offs. Role-play DevOps (wants to patch first), Business (concerned about revenue), and Legal (wants immediate action). Force team to make a decision within 5 minutes.

Expected Participant Response

Team debates options, makes decision with clear rationale, assigns action items, begins execution of chosen strategy.

If No Response After 10 Minutes

If discussion stalls, prompt: 'You have 2 minutes to make a decision. The attacker is still actively exploring your AWS environment. What's your call?'

Verification Checklist

- ☐ Decision made and clearly communicated
- ☐ Rationale documented
- ☐ Action items assigned to specific team members
- ☐ Timeline for execution established

Simulate Journalist Phone Call

Action to Perform

Runner role-plays journalist calling company main line. Ask specific questions about the breach. Note who responds and what information is shared.

Expected Participant Response

Call routed to appropriate spokesperson. Prepared statement provided if available. No unauthorized disclosures made.

If No Response After 10 Minutes

If no media policy exists, runner states: 'The receptionist who answered told me: We had a small technical issue earlier but it's resolved. She forwarded me to your IT director. 30 minutes later, TechCrunch publishes article with quotes. What's your response?'

Display GuardDuty Alert and Ransom Email

Action to Perform

Show GuardDuty finding for S3 DeleteObject activity. Then deliver ransom email to support inbox demanding 50 BTC or customer data will be deleted.

Expected Participant Response

Team recognizes destructive actions, checks S3 versioning, discusses ransomware response, engages Legal on ransom payment decision.

If No Response After 10 Minutes

If team doesn't engage with ransom demand, prompt: 'Legal is asking: Do we pay the ransom? Finance wants to know: Can we restore the data without paying? What's your recommendation?'

06 SOP/Playbook Gap Analysis



CRITICAL

SSRF Vulnerability Response Playbook

MISSING

Scenario Trigger: WAF alert for AWS metadata service access patterns (169.254.169.254)

Required Procedures:

- ☐ SSRF identification and validation procedures
- ☐ Application containment decision tree (shutdown vs. WAF block vs. patch-first)
- ☐ AWS credential rotation for compromised IAM roles
- ☐ Blast radius assessment (what resources can compromised role access)
- ☐ Emergency application patching procedures and SLAs

Impact if Missing: Delayed containment, continued credential abuse, extended attacker access window, broader cloud infrastructure compromise

Recommendation:

Develop comprehensive SSRF incident response playbook covering detection indicators (metadata service IPs, localhost requests, internal network access), immediate containment options with decision criteria, IAM credential rotation procedures with automation scripts, application security team notification workflows, and post-incident remediation including IMDSv2 enforcement and SAST tool deployment.

CRITICAL

AWS IAM Credential Compromise Response

INADEQUATE

Scenario Trigger: CloudTrail shows API calls from unauthorized IP addresses using valid credentials

Required Procedures:

- ☐ Immediate credential revocation methods (attach deny policy vs. role deletion vs. instance termination)
- ☐ Blast radius assessment for compromised IAM roles
- ☐ CloudTrail forensic analysis procedures and query templates
- ☐ Affected resource identification (enumerate all resources accessed by attacker)
- ☐ Automated credential rotation without service disruption

Impact if Missing: Extended attacker access window (6+ hours if credentials not revoked), broader compromise of AWS resources, difficulty determining scope of breach

Recommendation:

Create comprehensive AWS credential compromise playbook with step-by-step revocation procedures (with AWS console screenshots), pre-built CloudTrail query templates for common attack patterns, IAM policy templates for emergency deny-all policies, S3 access log analysis procedures, and automated credential rotation scripts callable via incident response platform.

CRITICAL

Data Breach Notification Procedures

MISSING

Scenario Trigger: 500K+ customer records exfiltrated from S3 containing PII

Required Procedures:

- ☐ Data breach assessment criteria (when is notification legally required)
- ☐ Legal and compliance team notification procedures
- ☐ Customer notification templates and delivery timelines
- ☐ Regulatory notification procedures (state AGs, GDPR DPAs, industry regulators)
- ☐ Internal stakeholder communication (executives, board, PR, customer support)
- ☐ Credit monitoring and identity theft protection vendor coordination

Impact if Missing: Regulatory non-compliance, potential GDPR fines (up to 4% of annual revenue), state-level fines, class-action lawsuits, loss of customer trust

Recommendation:

Develop data breach response playbook covering breach assessment decision tree with notification thresholds, 72-hour GDPR timeline tracker with milestones, customer notification templates (email, website, call center scripts), regulatory notification contact list with submission procedures, credit monitoring vendor pre-negotiated contracts, and post-breach customer support escalation procedures.

HIGH

S3 Data Exfiltration Detection and Prevention

INADEQUATE

Scenario Trigger: 8.4 GB transferred from S3 before detection

Required Procedures:

- ☐ Real-time S3 access monitoring with automated alerting

- ☐ S3 access pattern baseline (normal vs. anomalous behavior)

- ☐ Automated response to mass download events (alert SOC, block IP, revoke credentials)

- ☐ S3 bucket policies restricting access by source IP/VPC endpoint

- ☐ S3 Object Lock for immutable data retention

Impact if Missing: Late detection of data exfiltration, difficulty determining full scope of breach, inability to stop theft in progress

Recommendation:

Deploy S3 access logging with CloudWatch integration and real-time alerts for unusual API call volumes. Configure S3 bucket policies requiring VPC endpoint access.

Implement S3 Object Lock for critical customer data. Create automated SOAR playbook to revoke credentials when exfiltration detected. Establish S3 access baselines using CloudWatch Insights.

HIGH

Application Security Testing (SAST/DAST)

MISSING

Scenario Trigger: SSRF vulnerability in production code, no pre-deployment detection

Required Procedures:

- ☐ SAST tools in CI/CD pipeline scanning for injection vulnerabilities
- ☐ DAST or IAST testing for SSRF, SQLi, XSS in staging environment
- ☐ Security code review procedures for external-facing APIs
- ☐ Secure coding training for developers (OWASP Top 10 focus)
- ☐ Vulnerability disclosure and emergency patching workflows

Impact if Missing: Critical vulnerabilities deployed to production undetected, reactive security posture, emergency patching disrupts business

Recommendation:

Implement SAST tool (Semgrep, Checkmarx, or Snyk Code) in CI/CD pipeline with build-breaking rules for high-severity findings. Add DAST scanning to staging environment using Burp Suite or OWASP ZAP. Require security code review for all external-facing API changes. Provide quarterly OWASP Top 10 training for developers with hands-on vulnerable lab exercises.

HIGH

Media and External Communication Procedures

PARTIAL

Scenario Trigger: Journalist inquiry about data breach

Required Procedures:

- ☐ Media inquiry response procedures and routing
- ☐ Authorized spokesperson list with contact information
- ☐ Holding statement templates for active incidents
- ☐ Social media monitoring during security incidents
- ☐ Customer support escalation and FAQ preparation

Impact if Missing: Inconsistent messaging, unauthorized disclosures, PR damage amplification, stock price impact, customer confusion

Recommendation:

Develop incident communication playbook with media inquiry routing procedures, pre-approved holding statements for different incident types, decision tree for when to proactively disclose vs. respond to inquiries, social media monitoring alerts for company mentions during incidents, and customer support FAQ templates for common breach questions.

HIGH

AWS Security Baseline Compliance

INADEQUATE

Scenario Trigger: IMDSv1 enabled (allowed SSRF exploitation), S3 versioning gaps

Required Procedures:

- ☐ IMDSv2 enforcement for all EC2 instances (prevents SSRF metadata access)
- ☐ S3 versioning enabled on all critical data buckets
- ☐ CloudTrail log file integrity validation
- ☐ IAM role session duration limits (reduce credential lifetime)
- ☐ VPC endpoints for AWS services (prevent SSRF to AWS APIs)

Impact if Missing: SSRF attacks can access metadata service, accidental/malicious data deletion unrecoverable, credential theft impact window extended

Recommendation:

Conduct AWS security baseline audit using AWS Security Hub or Prowler. Immediately enforce IMDSv2 requirement for all EC2 instances. Enable S3 versioning with Object Lock for critical data. Reduce IAM session duration from default 6 hours to 1 hour. Deploy VPC endpoints for S3, EC2, and other services to prevent SSRF attacks from reaching AWS APIs.

MEDIUM

WAF Configuration and Tuning

INADEQUATE

Scenario Trigger: Critical WAF rules in detection-only mode instead of block mode

Required Procedures:

- ☐ WAF rule review and mode management (detection vs. block)
- ☐ False positive analysis and tuning procedures
- ☐ WAF alert prioritization and response workflows
- ☐ Regular WAF effectiveness reviews

Impact if Missing: Known attack patterns allowed through to application, delayed attack detection

Recommendation:

Review all AWS WAF rules and move critical rules (SSRF, SQLi, XSS patterns) from detection to block mode. Implement 30-day detection period for new rules before blocking. Create WAF alert response procedures with severity-based SLAs. Schedule quarterly WAF effectiveness reviews.

MEDIUM

CloudTrail Forensic Analysis Capability

LIMITED

Scenario Trigger: Manual log review required, no pre-built queries or automation

Required Procedures:

- ☐ CloudTrail query templates for common attack patterns
- ☐ Automated CloudTrail analysis tools and scripts
- ☐ CloudTrail log aggregation and search platform
- ☐ Training for SOC analysts on CloudTrail forensics

Impact if Missing: Slow forensic investigation, incomplete understanding of attacker actions, difficulty determining breach scope

Recommendation:

Create library of CloudTrail query templates for common scenarios (credential abuse, data exfiltration, privilege escalation). Deploy CloudTrail logs to centralized SIEM or CloudWatch Insights. Build automated analysis scripts for rapid breach scope determination. Provide CloudTrail forensics training to SOC team.

MEDIUM

Incident Response - Business Continuity Coordination

UNCLEAR

Scenario Trigger: Confusion about authority to take application offline (\$50K/hour impact)

Required Procedures:

- ☐ Incident commander authority matrix (who can approve business-impacting actions)
- ☐ Revenue impact estimation procedures for service disruptions
- ☐ Business continuity coordination workflows during security incidents
- ☐ Executive escalation thresholds and notification procedures

Impact if Missing: Delayed critical decisions, unclear accountability, uncoordinated response affecting business operations

Recommendation:

Define incident commander role with clear authority levels for different impact tiers. Document decision authority for business-impacting actions (e.g., CISO can approve up to 2-hour outage, CEO approval required beyond that). Create revenue impact calculator for common scenarios. Establish executive notification thresholds and briefing templates.

LOW

Vendor Security Incident Coordination

MISSING

Scenario Trigger: No procedures for notifying cloud provider or other vendors during incidents

Required Procedures:

- ☐ AWS security incident coordination procedures
- ☐ Vendor notification thresholds and timing
- ☐ Third-party incident response vendor contacts (forensics, legal, PR)
- ☐ Cyber insurance notification and claim procedures

Impact if Missing: Missed opportunity for vendor assistance, contractual violations, delayed insurance claims

Recommendation:

Document AWS support channels for security incidents (AWS Support, AWS Abuse team). Create vendor notification decision tree. Maintain list of pre-approved incident response vendors (forensics firm, breach coach law firm, PR crisis firm). Document cyber insurance notification requirements and claim procedures with policy details.

LOW

Post-Incident Review and Lessons Learned

INFORMAL

Scenario Trigger: No formal post-incident review process

Required Procedures:

- ☐ Post-incident review meeting scheduling and facilitation
- ☐ Lessons learned documentation format
- ☐ Action item tracking and accountability
- ☐ Incident pattern analysis and trend identification

Impact if Missing: Repeated incidents due to same root causes, failure to learn from experience

Recommendation:

Implement formal post-incident review process within 5 business days of incident closure. Use structured format covering timeline, root cause, response effectiveness, and improvement actions. Track action items like project deliverables with owners and deadlines. Conduct quarterly incident trend analysis to identify systemic issues.

07 Exercise Evaluation

Post-Exercise Debrief: Conduct after-action review within 48 hours. Focus on lessons learned and concrete action items with assigned owners.

After-Action Report Template

What Went Well

Document successes and effective responses (use during debrief)...

Areas for Improvement

Document challenges and improvement opportunities (use during debrief)...

Action Items

Action Item	Owner	Due Date	Priority